

Chapter 11: Network Attacks & Intrusion Techniques

CompTIA Security+ Study Slides

Walailak University — Assist. Prof. Dr. CJ

Learning Objectives

- Identify types of **network-based attacks**
- Understand **Denial of Service (DoS)** and **Distributed DoS (DDoS)**
- Explain **spoofing, session hijacking, and replay attacks**
- Describe **DNS, ARP, and transitive attacks**
- Apply defensive strategies and mitigation techniques

Overview

Network attacks exploit design flaws, misconfigurations, or weak authentication.

Goal of attackers:

- Disrupt availability
- Intercept communications
- Steal credentials or manipulate sessions

Categories of Network Attacks

Category	Description	Example
Availability	Disrupt service or deny access	DoS, DDoS
Interception	Eavesdrop on communications	MITM, sniffing
Modification	Alter or corrupt data	Spoofing, hijacking
Fabrication	Inject false data or sessions	Replay, DNS poisoning

Denial of Service (DoS)

Definition:

An attack that prevents legitimate users from accessing network resources by overwhelming the system.

Types:

- **Volume-based:** flood bandwidth (ICMP, SYN floods)
- **Protocol-based:** exploit protocol weaknesses (Ping of Death, Teardrop)
- **Application-layer:** exhaust application processes (HTTP flood)

Distributed Denial of Service (DDoS)

Definition:

A coordinated attack from multiple compromised systems (botnets).

Common Forms:

- **SYN Flood:** incomplete TCP handshakes exhaust resources
- **Smurf Attack:** ICMP echo request to broadcast address
- **Fraggle Attack:** UDP echo flood (port 7, 19)
- **Ping of Death:** oversized ICMP packets cause buffer overflow

 *Even large enterprises can be taken offline by DDoS.*

DDoS Example Diagram

[Botnet of 10,000 infected PCs]

↓

[Target Web Server]

↓

Crashed or Unresponsive

 Attackers often use **amplification** (e.g., DNS or NTP reflection) to multiply traffic.

DDoS Mitigation

- Use **rate limiting** and **traffic shaping**
- Deploy **load balancers** and **redundant servers**
- Use **anti-DDoS appliances** or **cloud scrubbing** services (e.g., Cloudflare, Akamai)
- Configure **firewall/IPS filters** for known botnet patterns
- Implement **blackhole routing** to discard malicious traffic

Spoofing Attacks

Spoofing: forging identity or address to appear legitimate.

Type	Description	Example
IP Spoofing	Falsifying source IP address	Used in DDoS or MITM attacks
MAC Spoofing	Imitating another device's MAC address	Bypass MAC-based filters
Email Spoofing	Fake sender address in phishing	CEO fraud, BEC scams
Caller ID Spoofing	VoIP identity forgery	Phone-based phishing (vishing)



Authentication and encryption mitigate spoofing.

IP Spoofing Explained

- Attacker sends packets using **forged source IP**
- Target replies to **spoofed IP**, not the attacker
- Commonly used in **DoS floods** or **MITM attacks**

Prevention:

- Enable **ingress/egress filtering**
- Use **stateful firewalls** and **IPsec**
- Verify IP ownership with **anti-spoofing ACLs**

Session Hijacking

Definition:

Taking over an established session by stealing or guessing a valid session token.

Methods:

- **Session fixation:** attacker sets session ID before login
- **Session side-jacking:** intercepts cookies via sniffing
- **TCP/IP hijacking:** manipulates sequence numbers to insert malicious packets

TCP/IP Hijacking Process

1. Establish a legitimate TCP session between two hosts.
2. Attacker intercepts or predicts sequence numbers.
3. Attacker injects malicious packets.
4. Session control shifts to attacker.

 **Encryption (TLS) and randomized sequence numbers** prevent hijacking.

Man-in-the-Middle (MITM)

Definition:

An attacker intercepts and possibly alters communication between two parties.

Techniques:

- ARP poisoning
- Rogue Wi-Fi hotspots
- SSL stripping (downgrade HTTPS to HTTP)

Prevention:

- Use **TLS/SSL encryption**
- Enable **certificate pinning**
- **Verify endpoint authenticity**

Man-in-the-Browser (MITB)

- Malware infects browser to modify transactions or web forms
- Common in financial and e-commerce systems
- Harder to detect because it occurs on client-side

Countermeasures:

- Endpoint protection (anti-malware, EDR)
- Browser sandboxing
- Digital transaction signing

Replay Attack

Definition:

Intercepting valid communication and retransmitting it to perform unauthorized actions.

Example:

- Capturing authentication tokens and replaying them to gain access.

Defenses:

- Use **nonces** and **timestamps** in protocols
- Apply **session tokens** that expire quickly
- Enable **multi-factor authentication (MFA)**

 *Replay attacks exploit weak or predictable authentication.*

DNS Attacks

Attack Type	Description	Mitigation
DNS Poisoning	Corrupting DNS cache to redirect traffic	DNSSEC, cache validation
Unauthorized Zone Transfer	Copying DNS records for reconnaissance	Restrict transfers to trusted servers
Hosts File Manipulation	Altering local DNS resolution	System file integrity checks
Pharming	Redirecting users to fake websites	SSL/TLS, DNS filtering

ARP Poisoning

ARP (Address Resolution Protocol) maps IPs to MAC addresses. Attackers exploit this by sending fake ARP replies to redirect traffic.

Effect:

Traffic intended for one host is sent to the attacker.

Mitigation:

- Enable **Dynamic ARP Inspection (DAI)**
- Use **VLAN segmentation**
- Apply **static ARP entries** for critical systems

Transitive Attacks

Concept: Attackers compromise one system and pivot to others that trust it.

- Example: compromise a partner's VPN to access corporate network.
- Exploits **improper trust relationships** or **weak segmentation**.

Defenses:

- Enforce network segmentation and zero-trust architecture
- Use least privilege and strict ACLs
- Monitor lateral movement with IDS/SIEM

Port and Protocol Exploits

- **Open Ports:** expose services like SSH (22), RDP (3389), SMB (445)
- **Default Credentials:** often exploited by worms and bots
- **Unencrypted Protocols:** (Telnet, FTP) leak credentials
- **Malformed Packets:** cause buffer overflow or system crashes

Prevention:

- Perform **port scanning** (Nmap) on your own systems
- Use **firewalls** and **IPS signatures**
- Replace legacy protocols with **secure alternatives** (SSH, SFTP)

Detecting Intrusions

- **IDS/IPS logs** show attack attempts
- **SIEM correlation** reveals patterns (multiple failed logins, traffic spikes)
- **Network baselining** helps identify anomalies
- **Packet capture tools** (Wireshark, Zeek) for forensic analysis

 Continuous monitoring detects attacks early.

Best Practices Summary

- Use **defense in depth** across all network layers
- Encrypt sessions (TLS, VPN, IPsec)
- Apply **patches, ACLs, and segmentation**
- Monitor for anomalies via SIEM and IDS
- Train users against phishing and spoofing

End of Chapter 11

Next: [Chapter 12 — Securing Networks & Wireless Systems](#)